

情報セキュリティポリシー

1. 文書管理情報

本文書は当行における情報セキュリティの基本方針および遵守事項を定めるものである。文書番号は ISP-001 とし、管理責任者は情報セキュリティ統括部長とする。

本版は第4.2版（2025年4月1日改定）であり、前版（第4.1版、2024年10月1日）からの主な変更点は、多要素認証の適用範囲拡大およびEDR導入に伴うウイルス対策条項の改定である。改定履歴は文書末尾の付録Aに記載する。

本文書の見直しは原則として年1回実施し、重大なセキュリティインシデント発生時または関連法令・基準の改定時には臨時見直しを行う。次回定期見直し予定日は2026年4月1日とする。

関連文書として「アクセス制御ポリシー（ISP-002）」「暗号化基準（ISP-003）」「データ保護ポリシー（ISP-004）」「リモートアクセスポリシー（ISP-005）」を参照のこと。これらの文書群は相互に補完関係にあり、一体として運用される。

2. 目的と適用範囲

本ポリシーは、当行の情報資産を機密性・完全性・可用性の観点から適切に保護し、顧客情報の漏洩防止および金融サービスの安定的な提供を確保することを目的とする。FISC安全対策基準（第11版）の技術基準・運用基準・設備基準への準拠を基本要件とする。

適用範囲は、当行の全役職員（正社員、契約社員、派遣社員、パートタイマーを含む）、および当行の情報システムにアクセスする外部委託先の要員とする。海外拠点についても本ポリシーの基本方針を適用し、現地法令との整合性を確保する。

対象となる情報資産には、電子データ、紙媒体の書類、情報処理設備、ソフトウェア、ネットワーク機器、およびこれらに関連する業務プロセスを含む。クラウドサービス上に保管される情報資産も本ポリシーの適用対象とする。

3. 基本方針

当行は、金融機関としての社会的責任を認識し、情報セキュリティを経営上の最重要課題の一つとして位置づける。経営陣は情報セキュリティに対するリーダーシップを発揮し、必要な経営資源を継続的に配分する。FISC安全対策基準
技-1（情報セキュリティ管理態勢の整備）に基づき、全社的な管理態勢を構築する。

情報セキュリティマネジメントシステム（ISMS）をISO/IEC 27001:2022に準拠して運用し、PDCAサイクルによる継続的改善を実施する。年1回以上の内部監査および3年に1回の外部認証審査を通じて、管理態勢の有効性を検証する。

サイバーセキュリティ対策については、金融庁「金融分野におけるサイバーセキュリティ強化に向けた取組方針」に基づき、多層防御の考え方を採用する。脅威インテリジェンスの活用、レッドチーム演習の定期実施（年2回以上）により、高度化するサイバー攻撃への対応力を維持・向上させる。

4. 組織体制

最高情報セキュリティ責任者（CISO）を取締役会の決議により任命し、情報セキュリティに関する最終的な意思決定権限と責任を付与する。CISOは取締役会に対し、四半期ごとに情報セキュリティの状況を報告する義務を負う。FISC安全対策基準

運-1（情報セキュリティ管理者の設置）に準拠した体制とする。

情報セキュリティ委員会は、CISOを委員長とし、各事業部門の情報セキュリティ責任者、リスク管理部門長、コンプライアンス部門長、IT統括部門長で構成する。委員会は月1回の定例会議を開催し、セキュリティ施策の審議・承認、インシデント対応方針の決定、予算配分の審議を行う。

CSIRT（Computer Security Incident Response Team）を情報セキュリティ統括部に常設し、セキュリティインシデントの検知・分析・対応・復旧を担当する。CSIRTは金融ISAC（Information Sharing and Analysis Center）に加盟し、業界内の脅威情報共有に積極的に参加する。インシデント発生時の初動対応は検知後30分以内に開始することを目標とする。

各部署には情報セキュリティ推進担当者を1名以上配置し、部門内のセキュリティ施策の推進、セキュリティ教育の受講管理、インシデント報告の窓口機能を担わせる。推進担当者は年2回のセキュリティ推進担当者研修を受講する義務を負う。

5. リスクアセスメント

情報資産のリスクアセスメントは、FISC安全対策基準 技-2（リスク評価）に基づき、年1回の定期評価および新規システム導入時・重大変更時の随時評価を実施する。評価手法はJIS Q 27005:2022（情報セキュリティリスクマネジメント）に準拠する。

リスク評価は、脅威の発生可能性（5段階）と影響度（5段階）のマトリクスにより定量化し、リスク値が15以上の項目は「高リスク」として優先的に対策を講じる。リスク値が8以上15未満は「中リスク」、7以下は「低リスク」として管理する。リスク受容基準はリスク値7以下とし、これを超えるリスクには軽減・移転・回避のいずれかの対応を行う。

リスクアセスメント結果はリスク台帳に記録し、情報セキュリティ委員会に報告する。リスク対応計画の進捗は月次でモニタリングし、対応期限超過の項目はCISOにエスカレーションする。外部脅威環境の変化（新種マルウェア、ゼロデイ脆弱性等）に応じて、臨時のリスク再評価を実施する。

6. 人的セキュリティ

全役職員は入行時および年1回の情報セキュリティ研修を受講する義務を負う。研修内容は、セキュリティポリシーの理解、フィッシング対策、ソーシャルエンジニアリング対策、インシデント報告手順を含む。FISC安全対策基準

運-15（セキュリティ教育の実施）に準拠した教育プログラムを実施する。

標的型攻撃メール訓練を四半期ごとに実施し、開封率10%以下を目標とする。開封率が20%を超えた部署に対しては追加研修を実施する。訓練結果は情報セキュリティ委員会に報告し、教育プログラムの改善に反映する。

システム管理者・セキュリティ担当者には、職務に応じた専門研修（CISSP、情報処理安全確保支援士等）の受講を推奨し、資格取得費用の補助制度を設ける。退職時には機密保持誓約書への署名を求め、貸与機器の回収、アカウント即日無効化を実施する。

7. パスワードポリシー

システムへのログインに使用するパスワードは、最低12文字以上とし、英大文字・英小文字・数字・記号の4種のうち3種以上を含む複雑性要件を課す。FISC安全対策基準 技-16 (利用者認証方式の採用) に基づく認証強度を確保する。

パスワードの有効期間は90日間とし、期間満了時に強制変更を求める。過去12回分のパスワード履歴を保持し、再利用を禁止する。連続5回のログイン失敗でアカウントを30分間ロックし、ロック解除にはヘルプデスクへの連絡を要する。

特権アカウント (管理者権限) のパスワードは最低16文字以上とし、有効期間を60日間に短縮する。特権アカウントのパスワードは特権アクセス管理 (PAM) システムで一元管理し、アクセス制御ポリシー (ISP-002) 第5章の規定に従う。

パスワードの平文保存を禁止し、bcryptまたはArgon2idによるハッシュ化を必須とする。ソルトは256ビット以上のランダム値を使用する。パスワードリスト攻撃への対策として、既知の漏洩パスワードデータベースとの照合チェックを実施する。

8. 多要素認証

勘定系システム、インターネットバンキング管理画面、リモートアクセス環境、クラウド管理コンソールへのアクセスには多要素認証 (MFA) を必須とする。FISC安全対策基準 技-17 (多要素認証の導入) に準拠し、認証要素の独立性を確保する。

認証要素は、知識要素 (パスワード) 、所持要素 (ハードウェアトークンまたは認証アプリ) 、生体要素 (指紋認証または顔認証) のうち2つ以上を組み合わせる。SMS認証はSIMスワップ攻撃のリスクを考慮し、2025年度末までにFIDO2/WebAuthnへの移行を完了する。

MFA認証デバイス (ハードウェアトークン) の管理は情報セキュリティ統括部が一元的に行い、紛失・盗難時には直ちに無効化する。認証アプリを使用する場合は、当行が承認したアプリケーション (Microsoft Authenticator、Google Authenticator) のみを使用可とする。

9. アカウント管理

アカウントの発行・変更・削除は、所属部署の上長の承認を経て情報システム部が実施する。アカウント管理台帳を整備し、全アカウントの一覧を最新の状態に維持する。FISC安全対策基準 運-19 (利用者IDの管理) に準拠した管理プロセスを確立する。

共有アカウントの使用は原則として禁止する。やむを得ず使用する場合は、情報セキュリティ委員会の承認を得た上で、使用者の特定が可能な追加的なログ記録措置を講じる。退職者のアカウントは退職日当日中に無効化し、30日後に完全削除する。

90日間以上使用されていない休眠アカウントは自動的に無効化し、利用再開には所属部署長の承認を必要とする。アカウントの棚卸しは四半期ごとに実施し、不要アカウントの削除を徹底する。詳細な権限管理についてはアクセス制御ポリシー (ISP-002) を参照のこと。

10. ウイルス対策

全端末にEPP (Endpoint Protection Platform) を導入し、リアルタイムスキャンを常時有効とする。パターンファイルは最低でも1日1回の自動更新を行い、更新失敗が3日以上続いた端末はネット

ワーク接続を遮断する。FISC安全対策基準

技-31 (不正プログラム対策) に準拠した多層防御体制を構築する。

EDR (Endpoint Detection and Response) を全業務端末およびサーバに導入し、振る舞い検知による未知の脅威への対応力を強化する。EDRのアラートはSOC (Security Operations Center) が24時間365日体制で監視し、重大度「高」以上のアラートは検知後15分以内にCSIRTへ通報する。

USBメモリ等の外部記憶媒体は、接続時に自動スキャンを実施する。業務上不要な外部記憶媒体の接続はデバイス制御ソフトウェアにより制限する。マルウェア感染が確認された端末は直ちにネットワークから隔離し、CSIRTの指示に基づきフォレンジック調査および復旧を実施する。

11. 認証ログ管理

認証に関するログ (成功・失敗とも) は、全システムにおいて取得・保存を義務付ける。ログにはタイムスタンプ (NTP同期済み)、ユーザID、アクセス元IPアドレス、認証結果、認証方式を記録する。FISC安全対策基準

技-40 (アクセスログの管理) および運-27 (ログの定期的点検) に準拠する。

認証ログの保存期間は最低1年間とし、勘定系システムのログは7年間保存する。ログは改ざん防止のためWORM (Write Once Read Many) ストレージまたは暗号化ハッシュチェーンによる完全性保護を実施する。暗号化方式の詳細は暗号化基準 (ISP-003) を参照のこと。

SIEM (Security Information and Event Management) によるログの相関分析を実施し、不正アクセスの兆候 (短時間の大量失敗、通常と異なるアクセス元、営業時間外のアクセス等) を検知する。異常検知時のアラートはSOCが対応し、必要に応じてCSIRTへエスカレーションする。

12. 罰則規定

本ポリシーに違反した役職員は、就業規則に基づく懲戒処分の対象となる。違反の重大性に応じて、戒告、減給、出勤停止、降格、諭旨解雇、懲戒解雇の処分を行う。故意による情報漏洩については刑事告訴を含む法的措置を講じる場合がある。

外部委託先の要員が本ポリシーに違反した場合は、委託契約に基づく措置 (作業停止、契約解除、損害賠償請求) を講じる。委託先管理の詳細はFISC安全対策基準
運-36 (外部委託管理) に準拠して別途定める。

違反の報告を受けた場合、情報セキュリティ統括部は速やかに事実関係を調査し、調査結果をCISOおよび人事部に報告する。内部通報制度を通じた違反報告については、通報者の保護を徹底する。